

ASSESSMENT TOOL 3 – ANSWER SCRIPT

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1411

Q1. Footprinting Tools – Conducting Competitive Intelligence.

Scenario: A cybersecurity consultant must perform a passive security assessment of ABC Technologies, gathering only publicly available information without directly interacting with the company's servers (i.e., pure OSINT — no active scanning).

1. Domain Registration Details — WHOIS Lookup

Tool: WHOIS (via whois.domaintools.com, ICANN Lookup, or the command `whois abctechnologies.com`)

What it reveals:

Registrant/organization name and registrar

- Domain creation, update, and expiry dates
- Name servers (NS records) used by the organization
- Administrative and technical contact details (if not privacy-protected)

Competitive intelligence value: Shows how long the company has operated online, which registrar/DNS provider it trusts, and sometimes contact details that hint at organizational structure or third-party vendors it relies on.

2. Employee Email Addresses — theHarvester / Hunter.io

Tool: theHarvester (aggregates data from Google, Bing, LinkedIn, etc.) and Hunter.io (finds/verifies professional email addresses tied to a domain)

Command example: theHarvester -d abctechnologies.com -b google,linkedin,bing

What it reveals: Employee email address patterns (e.g., first.last@abctech.com), names of staff, and sometimes job titles pulled from public sources.

Competitive intelligence value: Reveals naming conventions (useful for later social engineering awareness testing), key personnel/department structure, and potential entry points for spear-phishing simulations during authorized engagements.

3. Technology Stack — BuiltWith / Wappalyzer

Tool: BuiltWith (web-based) and Wappalyzer (browser extension)

What it reveals: CMS platform (e.g., WordPress), web server (Apache/Nginx/IIS), programming frameworks, JavaScript libraries, analytics tools, CDN and hosting provider, and third-party plugins in use.

Competitive intelligence value: Indicates the company's technical maturity, vendor relationships, and potential outdated/vulnerable components — useful for benchmarking against competitors and understanding infrastructure investment.

4. Publicly Exposed Subdomains — Sublist3r / crt.sh

Tool: Sublist3r (aggregates subdomains from search engines and DNS databases) and crt.sh (queries Certificate Transparency logs for issued SSL certificates)

Command example: sublist3r -d abctechnologies.com

What it reveals: Subdomains such as dev.abctechnologies.com, mail.abctechnologies.com, vpn.abctechnologies.com, or staging environments that are publicly resolvable.

Competitive intelligence value: Maps the organization's external digital footprint — showing new product launches (staging/beta subdomains), internal tools exposed externally, and overall attack surface size.

Summary: Together, WHOIS, theHarvester/Hunter.io, BuiltWith/Wappalyzer, and Sublist3r/crt.sh let the consultant build a complete passive profile of ABC Technologies — ownership, people, technology, and infrastructure — entirely from public sources, with zero direct interaction with company servers.

Q2. DNS Zone Transfers.

Scenario: During an authorized penetration test, the analyst suspects the target's DNS server may be misconfigured to allow unauthorized zone transfers (AXFR).

Tool / Command to Test for Zone Transfer

Using dig:

- `dig axfr @ns1.targetdomain.com targetdomain.com`

Using nslookup (interactive mode):

- `server ns1.targetdomain.com`
- `set type=any`
- `ls -d targetdomain.com`

Other tools: Fierce, dnsrecon (`dnsrecon -d targetdomain.com -t axfr`), or DNSenum can automate this check across all listed name servers.

If the Transfer Succeeds

A successful AXFR dumps the entire DNS zone file, which typically includes:

- **Internal hosts:** A / AAAA records
- (e.g., dev01, db-server, internal-app) — revealing naming conventions and internal network layout, even servers never meant to be public.
- **Mail servers:** MX records
- identifying the mail infrastructure, useful for targeting phishing/spoofing or checking for open relays.
- **Subdomains & aliases:** NS, CNAME, TXT (SPF/DKIM) records
- exposing additional subdomains (VPN gateways, admin panels, staging sites) and email authentication configuration.

Reconnaissance Value & Risk

This single misconfiguration can hand an attacker a near-complete internal network map without any brute-forcing — turning passive/semi-passive recon into a full asset inventory. It significantly accelerates later attack phases (scanning, targeting) because the attacker already knows which hosts exist and what they likely do.

Recommended Countermeasure (for the report)

- Restrict zone transfers to explicitly authorized secondary DNS servers only (allow-transfer directive in BIND, or equivalent).
- Use TSIG (Transaction Signature) to authenticate zone-transfer requests.
- Regularly audit DNS server configuration for unauthorized AXFR access.

Q3. Introduction to Social Engineering.

Scenario: Employees receive an email claiming to be from IT, asking them to verify login credentials via a link, citing an urgent security update.

Type of Attack: Phishing (Credential-Harvesting / Pretexting Email Phishing)

This is a classic phishing attack — specifically one using pretexting (impersonating a trusted internal authority, "IT department") combined with urgency ("urgent security update") to pressure the victim into acting without verifying the request. The end goal is credential harvesting via a spoofed login page.

Key red flags in the scenario:

- Unsolicited request to "verify" credentials — legitimate IT rarely asks this by email.
- Artificial urgency designed to bypass careful thinking.
- A link leading to what is likely a fake/cloned login page.

Countermeasures Employees Should Follow Before Responding

1. Do not click the embedded link.
2. Verify the sender's actual email address/domain — check for spoofed or look-alike domains.
3. Hover over the link (without clicking) to inspect the real destination URL.
4. Contact IT directly through a known, official channel (phone, internal ticketing system) to confirm whether the request is genuine.
5. Never enter credentials on a page reached via an email link — instead navigate to the official site directly or use a bookmarked URL.
6. Check for generic grammar, spelling errors, or mismatched branding common in phishing emails.
7. Report the email to the security/IT team using the organization's phishing-report mechanism.

8. Ensure Multi-Factor Authentication (MFA) is enabled on the account as a backup layer of defense.

How These Actions Prevent Credential Theft

- Verifying the sender and contacting IT through a trusted channel breaks the attacker's pretext before any action is taken.
- Avoiding the link entirely prevents the victim from ever reaching the spoofed credential-harvesting page.
- Entering credentials only via known, bookmarked URLs ensures they are never submitted to an attacker-controlled site.
- MFA renders a stolen password insufficient on its own, blocking account takeover even if credentials are leaked.
- Prompt reporting allows the security team to block the sender/domain and warn other employees, containing the campaign before it spreads.

Conclusion: This scenario is a textbook phishing attack relying on authority and urgency. User awareness (verify-before-you-click), technical controls (email filtering, DMARC/SPF/DKIM), and MFA together form the layered defense that prevents credential theft.